

The CISO's briefing: Risk appetite

✓ The question that comes before all controls



Session objectives

By the end of this sequence:

- **Define** risk appetite and distinguish it from risk tolerance and the acceptance threshold
- **Formulate** a risk appetite statement usable by executive management: testable, dated, carried by the right body
- **Apply** the appetite governance established in session 1 to the MERIDIAN group: who sets it, who approves it, who breaks it down, and what the CISO really does
- **Confront** the findings of the session 4 audit report with a proposed appetite, and draw immediate decisions from them
- **Analyze** a real executive decision in the face of a cyberattack in terms of appetite and tolerance

Prerequisites

- The governance established in session 1: Executive Management sets the risk appetite, the Board of Directors approves it, the Executive Committee validates its operational and budgetary roll-out, and the Group CISO (RSSI Groupe) drafts the PSSI (the group's framework information security policy, French acronym) and arbitrates cross-subsidiary conflicts.
- The audit report produced in session 4, with its deviations qualified by subsidiary: it is what makes this morning's question urgent.
- The mapping from session 2: business assets, supporting assets and DICT (availability, integrity, confidentiality, traceability, the French acronym kept by the module) needs, including the Top 5 critical assets.

What to know before the exercise

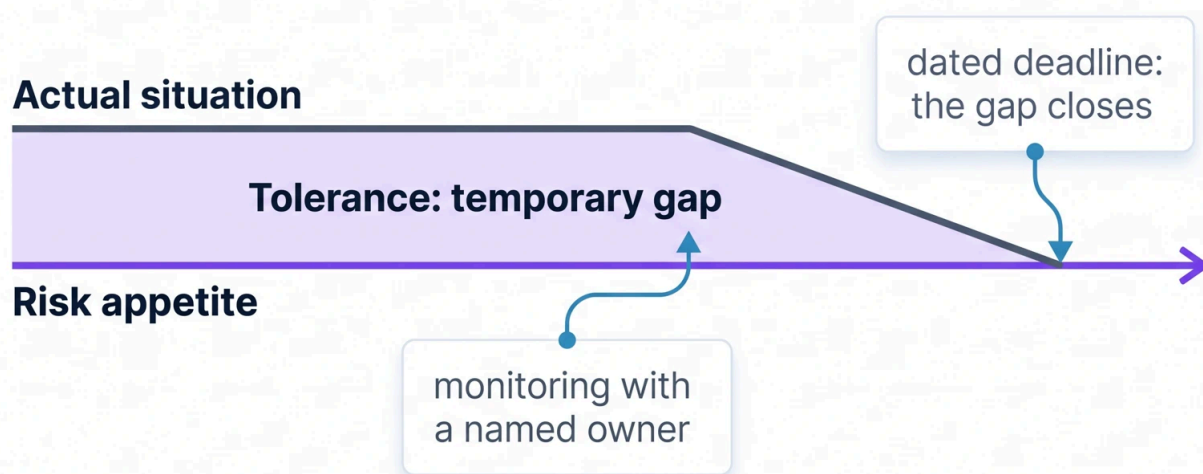
Last week's audit report put deviations down in black and white. The natural reaction of an executive team reading it is to ask: "fix everything". The CISO's reaction must be different, and that is the whole point of this CISO's briefing: fixing everything costs more than the group's budget, and not everything deserves to be fixed. Deciding what to treat first requires knowing how much risk the group agrees to carry. That quantity has a name.

Risk appetite is defined by the guide published jointly by ANSSI (the French national cybersecurity agency) and AMRAE (the French risk and insurance management association) in 2019, « Maîtrise du risque numérique - l'atout confiance » (Mastering digital risk: trust as an asset): « L'appétence aux risques est le niveau de risque qu'un dirigeant accepte de prendre pour soutenir les activités et le développement de son organisation. Elle appuie les décisions stratégiques et oriente les opérations. » (Risk appetite is the level of risk an executive agrees to take to support the activities and development of the organization. It underpins strategic decisions and guides operations.) Both halves of the sentence are worth remembering. The first says that accepting risk is not a weakness: it is an executive choice, made so that the business can live. A company with zero appetite opens no website, no warehouse, no online service. The second half says what appetite is for: deciding. An appetite statement that cannot settle any concrete decision is a wish, not a tool.

The same guide specifies the link with the neighboring notion: « l'appétence aux risques définit le seuil d'acceptation des risques de l'organisation » (risk appetite defines the organization's risk acceptance threshold).

The acceptance threshold is thus the operational translation of appetite: the line above which an identified risk is no longer acceptable as it stands and calls for a treatment decision. Appetite is an executive orientation; the threshold is the rule deduced from it to examine each risk, one by one. The end of the day will show that this threshold takes concrete shape on a rating grid; this morning, what matters is knowing who sets it and why.

That leaves **risk tolerance**, which professional vocabulary distinguishes from appetite without any official text in the course corpus defining it: it is therefore defined here for the module. Tolerance is the temporary gap the organization accepts between its appetite and its actual situation, with monitoring and a deadline. TRAMONTANE, the fictional online retailer of outdoor equipment that serves as the module's example, can have a very low appetite for the unavailability of its e-commerce site and yet tolerate, for six months and under surveillance, a known gap on the software of its Rivesaltes warehouse, because fixing it takes six months. Tolerance is not appetite in disguise: it is dated, monitored, and it closes.



Notion	What it is	Who carries it	Its hallmark
Risk appetite	The level of risk accepted to support the business	Executive management, approved by the governance body	Strategic, stable, guides all decisions
Acceptance threshold	The line above which a risk calls for treatment	Deduced from the appetite, applied by risk management	Operational, applies risk by risk
Risk tolerance	The temporary gap accepted between appetite and reality	Decided case by case, with monitoring	Dated, monitored, closes

This table is the exercise's safety net: when a sentence heard in committee mixes the three notions, it is almost always passing off an undated tolerance as appetite, and that is exactly the kind of slippage a CISO must catch in flight.

A real case to anchor all of this. In 2019, the Norwegian aluminum producer Norsk Hydro was hit by ransomware that paralyzed part of its plants. Management refused to pay the ransom, switched production to manual mode and communicated publicly, day after day, on the state of its systems. Norsk Hydro estimated the financial impact of the cyberattack at between 250 and 300 million Norwegian kroner for the second quarter of 2019. That decision reads through the three notions just laid out: management had zero appetite for financing a criminal group and for losing control of its data, and a deliberate appetite for an enormous but bounded operational cost. It preferred a heavy, measurable financial impact to a precedent it judged unacceptable. That is what a working appetite looks like: it was known before the crisis, and it made fast decisions possible during it.

💡 A method reflex: an appetite is always stated relative to something one agrees to lose or degrade, never in the absolute. "We are cautious" commits to nothing. "We accept delaying a delivery, never exposing a patient record" commits to everything.

✓ Case study: getting the MERIDIAN group's appetite set

Scenario and problem statement

Tuesday, 17:30. The Chief Executive Officer of the MERIDIAN group comes out of the audit report presentation and holds back the Group CISO: "Your report says that Logistique runs its industrial and office networks together, and that Santé has passwords without two-step verification. The Managing Director of Logistique tells me that nobody touches the automated systems in peak periods, and that peak periods run ten months out of twelve. The Medical Director of Santé tells me that an extra authentication step on a care workstation is time taken from the patient. Internal Audit tells me that Santé has still not handed over its register of administration accounts, and that we are gambling with patient data. They are all right, and I am not going to arbitrate thirty times a year. Give me what it takes to set a rule once and for all: what the group accepts, what it does not. I want your proposal on Thursday; I will take it to the Board of Directors."

The Group CISO has the session 4 audit report, including its deviations qualified by subsidiary: local passwords without MFA (multifactor authentication) at MERIDIAN Santé (healthcare), interconnected IT (business IT) and OT (industrial IT) networks at MERIDIAN Logistique (logistics), shared administrator accounts at MERIDIAN Éducation (education), logs kept locally at MERIDIAN Territoires (local public services). Added to that are the mapping and the Top 5 critical assets from session 2, and the governance established in session 1.

This morning's task: prepare the appetite proposal that Executive Management will set, in the forms the group's governance requires.

Guided questions

1. **Classify** the following three sentences, heard at the last Executive Committee, according to whether they express an appetite, a tolerance or an acceptance threshold, justifying each in one sentence: "No project will be blocked more than 48 hours for a security review"; "We keep the IT/OT interconnection until the next off-peak window, with reinforced monitoring, and we revisit it next quarter"; "Any risk rated above the high level on our future grid will have to be treated before going to production".
2. **Draft** two appetite statements: a first one on the asset to be protected of the subsidiary under review, that is, the one whose pack the group holds, as §2 of the subsidiary pack names it; a second one transverse to the

group, valid for all four subsidiaries. Constraint: each statement must make it possible to settle at least one concrete decision the group actually has in front of it, stating which one.

3. **Confront** each of the four audit deviations with the drafted statements and the spirit of the proposed appetite: which are clearly above the line, which fall under a tolerance to be formalized, and what does each tolerance still lack to qualify as one?
4. **Assign** the roles for Thursday: who sets the appetite, who approves it, who validates its budgetary roll-out, and what exactly remains in the Group CISO's hands? Identify the posture trap awaiting the CISO in the CEO's sentence.
5. **Analyze** Norsk Hydro's 2019 decision with the morning's vocabulary: formulate in two sentences the implicit appetite revealed by the refusal to pay, and what that decision would have looked like had it needed to be improvised without a prior appetite.

Working method

Address the questions in order: question 1 checks the definitions, questions 2 and 3 build the proposal, questions 4 and 5 put it in perspective. For the statements in question 2, apply the table's test: an appetite statement that neither wins nor loses a real decision is to be rewritten. Allow 10 minutes for question 1, 15 minutes for questions 2 and 3, and 5 minutes for the last two.



Answer key and assessment criteria – cliquer pour révéler

+10 XP

Leçon terminée